Cyber Fundamentals Coursework 1

5655691

Table of Contents:

1 Executive summary

2 Background

3 Analysis
3.1 The threat actor
3.2 Initial reconnaissance
3.3 Access to the system
3.4 Further reconnaissance
3.5 Execution of ransomware
3.6 Result of ransomware attack

4 Attack graph

5 Recommendations
5.1 multi-factor authentication
5.2 Investment in the system
5.3 Network segmentation

Reference list

1 Executive summary

The attack on the British Library was by a group claimed to be the Rhysida ransomware group, who infiltrated the network, exfiltrated and encrypted the data within, targeting certain departments and gathering personal information. This was due to the fact that the Library had lacking security measures, with one of the main reasons being Multi-Factor Authentication not being implemented on all systems, allowing for certain endpoints, primarily suppliers, to be exploited in order to gain initial access. The report covers the impact of attacks on UK universities, and what is believed to have happened in the British Library attack, an important third-party resource for UK universities.

2 Background

Universities are a huge target for cyber attacks due to the vast amount of data that they hold, including information such as personal data of students, teachers and employees, as well as academic research and intellectual property. Over the past years, attacks against higher education institutions have increased, for example from 2022 to 2023 there was a 70% increase in attacks based only on incidents where a ransom was not paid, 68 in 2022 to 116 in 2023 [Threatdown, 2024]. The main motivation that attackers have for targeting universities is financial gain, as universities receive significant funding from sponsors and the government for research, making them a prime victim for extortion. Other reasons include theft of data, such as research or intellectual property, or personal data which can be sold on the dark web or used for identity theft, or to merely disrupt services for political or social campaigns. A recent example of an attack on a UK university is the DDoS attack on the University of Cambridge in February 2024. DDoS, known as a Distributed Denial-of-Service attack, is a method of cyber attack in which the attacker overwhelms the server with traffic in order to prevent other users from connecting to it, which the University of Cambridge experienced on the 19th February 2024. The disruption affected IT services such as Moodle and CamSIS, the university's system for handling student information, records and transactions. It is used by staff, students and alumni, and is the source of statutory governmental reports that secure the university's funding [Camsis, 2024]. Had the disruption caused permanent damage, it would have severely affected the university in terms of lost data as well as money. The reasoning being "UK's unconditional support for Israel and complicity on the ongoing genocide in Gaza as well as bombing campaigns on Yemen" [Armstrong, Mann, 2024]. This is effective as tens of thousands of people are directly affected by the attacks, due to the DDoS, as well as spreading the message nationwide due to the prestigious reputation of the university, resulting in increased media coverage, in turn extending the reach of their message. Another attack that occurred since 1st October 2023 occurred a day after the DDoS attacks, on the University of Wolverhampton, on the 20th February 2024. While very little details were shared online, it has been shared that it had caused thousands of staff and students to work remotely [Kundaliya, 2023]. Despite the timing being very close between the attacks on the universities, Anonymous Sudan had not claimed to be behind the attack for the second. As it had not been claimed by any group, it is likely that it was not to send a message as opposed to the previous attacks recently on UK universities.

3 Analysis

3.1 The Threat Actor

The likely threat actor, referred to as the attacker throughout the analysis, has claimed responsibility as the Rhysida ransomware gang. Rhysida is a ransomware scheme that is operated by a cybercriminal threat group called GOLD VICTOR. Rhysida is not a ransomware-as-a-service (RaaS), meaning it is not sold to other hackers. Before late 2021, they had operated Vice Society, another group that used ransomware to encrypt systems, similar to the British Library attack. [Secureworks, n.d]. Rhysida works by using different methods to both gain access, and keep presence in a system, also known as persistence. Methods include phishing, particularly spear-phishing, involving attachments that contain malware or using links to redirect to a site that leads to downloading malware. They also make use of vulnerabilities, which may include legacy systems which do not have updated security patches, leading to vulnerabilities exposed. Another method utilised is remote desktop protocol, by using stolen credentials or vulnerability exploits to gain access to the system.

3.2 Initial Reconnaissance

The first part of the kill chain is reconnaissance, which identifies the targets, the British Library in this instance. It involves gathering information about the Library system, network, and personnel. Passive reconnaissance uses public information on targets, such as social media profiles on LinkedIn to find key personnel, and information shared on their website and news articles to gain details on any operations, such as when the system might be down for maintenance, giving attackers a window when it is most vulnerable. It may also be used to gather email addresses which can be used for phishing campaigns, which in this case would likely have downloaded malware to gather account details of people with privileged access, shown in the attack graph as one of the ways that attackers could have gained initial access. Social engineering involves engaging with employees or users to gather information such as security measures or possible vulnerabilities without raising too much suspicion. The other method is active reconnaissance which involves engaging with the system to find vulnerabilities, which can be done through automated scanning or manual testing. Port scanning techniques are usually used, which identify open ports to a network, allowing attackers to infer which services are visible and where attack is possible from [ASM, 2020]. Information gathered likely showed that the British Library had many trusted partners which did not have multi-factor authentication (MFA), which was likely exploited through the previously mentioned phishing campaigns to gather compromised credentials.

3.3 Access to the System

During the Covid-19 pandemic there was an increase in the usage of remote desktop technology because of employees working at home, alongside the increasing use of third-party providers within the network, on a Terminal Services server installed in February 2020, which was designed to provide remote access to the Library's network for various users, including external partners and IT staff. This opened up greater access points, and it was in the Terminal Services server that the first detected unauthorised access had been identified at. Security across the network was not consistent, in

particular the fact that while the terminal server was protected by firewalls and virus software, there was a lack of MFA, where users are required to enter more information than just a password, such as entering a code sent to email [AWS, 2023]. Although it had been implemented on cloud applications, it was not used for on-premise access due to considerations such as practicality, cost and impact of ongoing library programmes. These factors are most likely the reason why attackers were able to gain access to the Library system so easily. Due to the large reliance on legacy infrastructure, and having inadequate monitoring software, it was revealed that attackers had been in the system for at least 3 days before the attack was detected.

3.4 Further Reconnaissance

Since the attack had claimed to be by the Rhysida ransomware group, they likely created ransomware used in the attack, which in August 2023 had been reported by the Health Sector Cybersecurity Coordination Center (HC3) to be in early stages of development. However, after this alert was published, it proved to be more of an advanced threat than what had been assumed [Barry, 2024]. Once attackers had gained access to the internal servers, it can be assumed that there were other steps involved before deploying the ransomware, for example lateral movement, involving further reconnaissance inside the system. It identifies valuable assets such as locations of personal data, scanning for open ports, mapping out the system topography, identifying user accounts of interest and other potential systems it can compromise. This information allows for persistence, when an attacker maintains a foothold in the system without being detected and being impacted by any kind of disruption [Compean, 2023]. In addition, the attackers most likely looked to elevate permissions in the network, privilege escalation, exploiting vulnerabilities found, such as a bug or finding credentials with greater access. Once they have gained sufficient privileges, they can move to other systems in the network, known as lateral movement. This involves using administration tools or exploiting trust relationships between the systems, gaining access to more resources which may be used for ransom. While not explicitly detailed in the report, it is implied by the fact that the attackers had executed targeted attacks, copying records from different departments, and the use of keyword scanning suggested that attackers searched for specific files or folders which would require access to multiple resources.

3.5 Execution of Ransomware

Once they have enough privileged access, attackers can begin the deployment of the ransomware software. The Library's reliance on legacy systems meant that despite having modern tools, it was unable to fully scan the topography, resulting in only partially isolating the attack. Attackers begin by collecting data by a method called wholesale attacks, targeting large volumes of data for specific sections in the network, as opposed to individual files or smaller databases. This allows for targeted data collection, aimed at copying entire sections of data from specific departments in the British Library, mentioned in 3.6. This allows attackers to gather vast amounts of sensitive data quickly. It is good for ransomware schemes as it causes huge disruption for the British Library as it leads to the compromisation of valuable documents, leading to financial or reputational damage. The attackers also hijacked administrative IT tools and created backup copies of 22 of the Library databases. This

data was then exfiltrated, taken by the attackers in a short period of time, and is encrypted in order to make the data inaccessible and slowing down system recovery, consequently trying to pressure the British Library into paying a ransom. The Rhysida binary is executed using PsExec, a tool that allows you to run programs on remote systems, which is relevant seeing as there was an increasing reliance on remote access during the pandemic. The ransomware leaves data encrypted and renamed with a .rhysida file extension, although not mentioned in the report. A ransom note is then dropped on infected systems, a PDF named “CriticalBreachDetected.pdf” [Barry, 2024]. The attackers used techniques to evade detection in the system and cover their tracks, such as anti-forensics. This may involve actions such as deleting or encrypting files to make it difficult to access or installing malware to hinder analysts from recovering data. [Cybersecurity Exchange, 2022].

3.6 Result of Ransomware Attack

After the ransomware was deployed, 600GB worth of data had been stolen, including personal data of staff and users, in which 60% of data copied was from key departments, in particular the Finance, Technology and People teams as well as the previously mentioned keyword scanning which had files copied that contained sensitive terms such as “passport” or “confidential”, estimated to have represented 40% of the copied documents. In the backup databases copied, some contained contact details of users, although it is not believed to contain sensitive details such as bank details. This data was held for ransom, which the British Library did not pay, and in order to monetise the stolen data, it was found on their leak site to be put up for auction with a starting bid of 20 bitcoin, or about £590,000 [Milmo, 2023]. In addition, significant portions of data and parts of servers were destroyed, which inhibited system recovery and recovering the encrypted data.

4 Attack graph

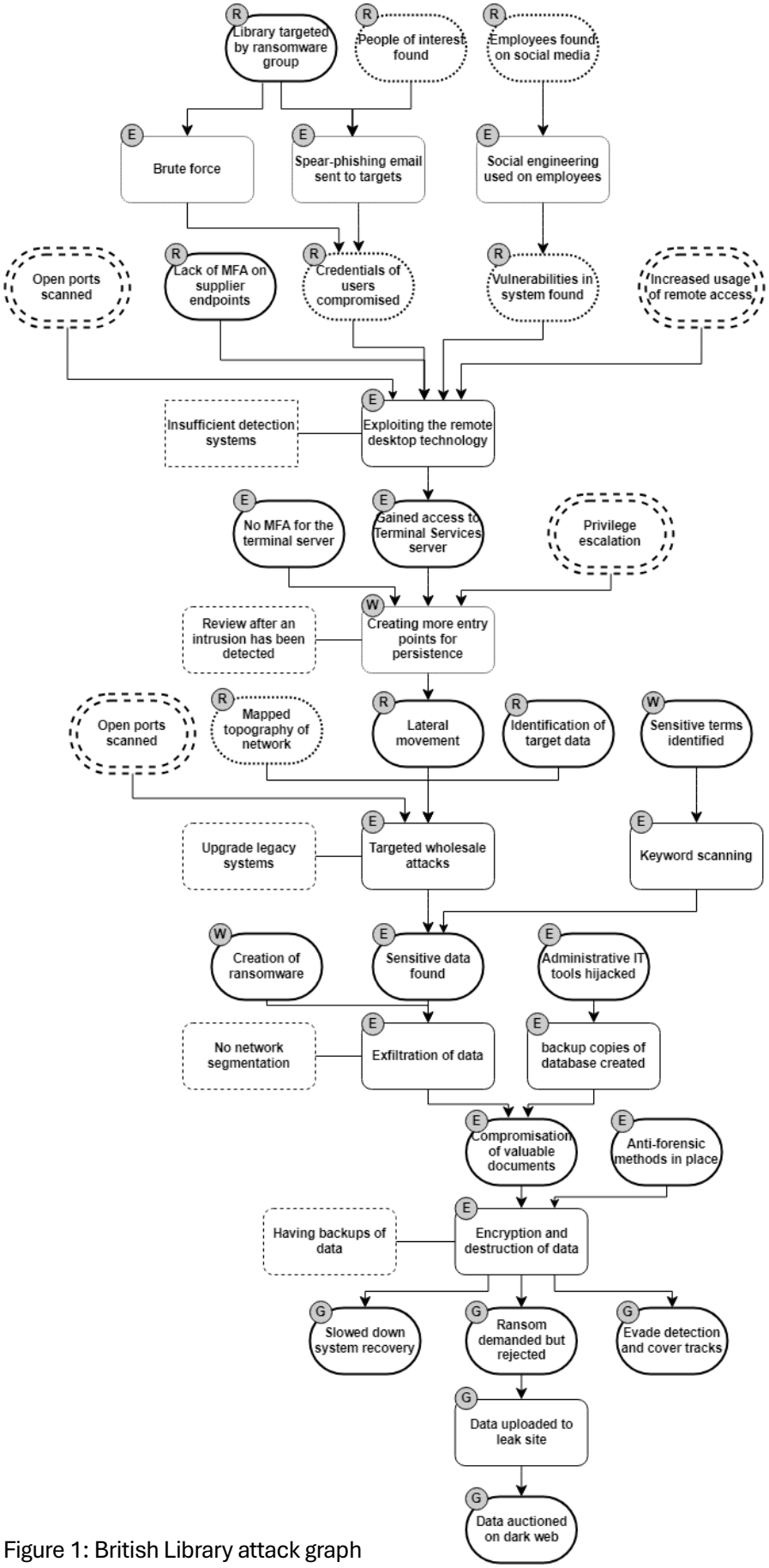


Figure 1: British Library attack graph

5 Recommendations

5.1 Multi-Factor Authentication

One of the main reasons that attackers were able to gain privileged access so easily was due to the fact that there was a lack of MFA on different parts in the structure of the British Library system. While MFA was implemented on applications such as emails, Teams and Word, it was not used everywhere, including areas such as local servers and supplier endpoints, which as seen from 3.2 had been identified to have privileged access to the system, meaning having those account details being compromised would allow for attackers to have significant access, due to the fact that there was no other security in place to log in. The prioritisation of implementing MFA on all systems, including partner systems and locally would help to mitigate the risk of access via phishing campaigns.

5.2 Investment in the System

Following the initial access to the system, it was noted that despite the system having detected that there been an intrusion, it was not investigated further due to the fact that it was running on legacy systems, as well as the response methods and software at the time being unable to isolate the threat before it gained access to sensitive data. This resulted in allowing the initial breach through and most of the ransomware becoming successfully deployed without being monitored properly, and not being contained before it caused permanent damage, such as the theft and deletion of data. The British Library should aim to improve security systems that are already in place by hiring specialists that can respond when an intrusion is flagged in the security system to do an in-depth review, preventing persistence and circumnavigating any security implementations. In addition, investment into their systems would enable the Library to utilise their security tools to their fullest potential, as it was likely that despite having modern security tools, it was unable to provide complete coverage or protection to the network.

5.3 Network Segmentation

The attack on the British Library, as stated in 3.5, involved wholesale attacks, which gathered large amounts of data at once. This was possible due to the fact that once they had gained a certain level of access, they were able to access files from multiple different departments, and exfiltrate all the information. In addition, it meant that the destruction and encryption of data was easier due to the fact that it was accessible by just having access to the network. By implementing network segmentation, it can help to prevent large damage, as it separates the data, reducing the attack surface. In addition, administrators can control the traffic between the different segments, which acts as another layer of security as it isolates the breach to one area.

Reference List:

Armstrong, F. and Mann, E. (2024). *Cambridge faces cyber attack*. [online] Varsity Online. Available at: https://www.varsity.co.uk/news/27131.

ASM , Rockville , Maryland. (2020). *Active Vs Passive Reconnaissance*. [online] Available at: https://asmed.com/active-vs-passive-reconnaissance/.

AWS (2023). *What is Multi-Factor Authentication (MFA)? - Cloud Security Beginner's Guide - AWS*. [online] Amazon Web Services, Inc. Available at: https://aws.amazon.com/what-is/mfa/.

Barry, C. (2024). *Rhysida ransomware: The creepy crawling criminal hiding in the dark*. [online] Barrcuda Blog. Available at: https://blog.barracuda.com/2024/05/09/rhysida-ransomware--the-creepy-crawling-criminal-hiding-in-the-d.

Cam.ac.uk. (2024). *CamSIS* |. [online] Available at: https://www.camsis.cam.ac.uk [Accessed 5 Dec. 2024].

Compean, N. (2023). *What is Persistence in Cybersecurity and How Do You…*. [online] BeyondTrust. Available at: https://www.beyondtrust.com/blog/entry/what-is-persistence-in-cybersecurity.

Cybersecurity Exchange. (2022). *Five Anti-Forensic Techniques Used to Cover Digital Footprints*. [online] Available at: https://www.eccouncil.org/cybersecurity-exchange/computer-forensics/anti-forensic-techniques-used-to-cover-digital-footprints/.

Kundaliya, D (2023). *Cyber incident disrupts another UK university*. [online] Computing.co.uk. Available at: https://www.computing.co.uk/news/4178362/cyber-incident-disrupts-uk-university?itc=refresh [Accessed 5 Dec. 2024].

Lockheed Martin (2015). *GAINING THE ADVANTAGE Applying Cyber Kill Chain® Methodology to Network Defense*. [online] Available at: https://www.lockheedmartin.com/content/dam/lockheed-martin/rms/documents/cyber/Gaining_the_Advantage_Cyber_Kill_Chain.pdf.

Milmo, D. (2023). Rhysida, the new ransomware gang behind British Library cyber-attack. *The Guardian*. [online] 24 Nov. Available at: https://www.theguardian.com/technology/2023/nov/24/rhysida-the-new-ransomware-gang-behind-british-library-cyber-attack.

National Cyber Security Centre (2018). *Phishing attacks: defending your organisation*. [online] NCSC.gov.uk. Available at: https://www.ncsc.gov.uk/guidance/phishing.

Secureworks. (n.d.). *GOLD VICTOR | Threat Profile Detail | Secureworks*. [online] Available at: https://www.secureworks.jp/research/threat-profiles/gold-victor [Accessed 28 Nov. 2024].

ThreatDown by Malwarebytes. (2024). *2024 State of Ransomware in Education: 92% spike in K-12 attacks - ThreatDown by Malwarebytes*. [online] Available at: https://www.threatdown.com/blog/2024-state-of-ransomware-in-education-92-spike-in-k-12-attacks/